

ACCESS CONTROL & PERMISSIONS AUDIT

Role-Based Page Access Report

CATS Practice Management Platform — pages accessible per role and the actions permitted on each

Prepared: August 7, 2026

Scope: All authenticated roles (Admin, Therapist, Client) and public/unauthenticated access

Source: Application routes, controllers, and middleware as of current codebase state

1. Overview

How access control is implemented in this application

The platform is a Laravel 13 + Inertia/React application for a therapy clinic. Users belong to exactly one of three roles, stored as a plain `role` string on the users table: **admin**, **therapist**, and **client**. There is no separate permissions table — access is enforced two ways:

- **Route-level middleware** — routes are grouped under `/admin`, `/therapist`, and `/client` prefixes, each guarded by a `role:<name>` middleware that redirects users who don't match to their own role's home page.
- **In-controller checks** — several controllers (Sessions, Invoices, Complaints) are shared across role groups and self-scope their queries and edit rights based on the logged-in user's role (e.g. a therapist only ever sees their own sessions and invoices; a client only sees their own).

Note: There are no formal Laravel Policy classes or Gates in this app — all authorization logic lives in route grouping and inline role checks inside controllers. This report documents the effective, observed access rules.

Role Summary

Area	Public (Guest)	Client	Therapist	Admin
Marketing site / careers / apply for services	Full	Full	Full	Full
Own calendar / sessions	—	View + verify/dispute	Full manage (own)	Full manage (all)
Own invoices	—	View only	View/create/edit (own)	Full manage (all)
Intake applications	Submit only	—	Review assigned only	Full pipeline control
Clients (records)	—	Own profile only	Assigned clients only	Full manage all
Job applicants / hiring	Submit only	—	—	Full manage
Staff / team management	—	—	Own profile only	Full manage + permissions
Complaints/disputes	—	File own	File own	Review + resolve all
System settings / audit log / user roles	—	—	—	Full control

2. Public / Unauthenticated Access

No login required — marketing site, service catalog, and application intake forms

Page	Route	What they can do
Home, About, Team, FSCD info, FAQ, Legal pages	/, /about, /team, /fscd, /faq, /terms...	View informational content only
Services catalog	/services, /servicesDetails/{service}	View list and detail pages
Careers listing & job detail	/careers, /careers/{career}	View open positions
Career application	/careers/apply/{career?}	Submit a job application (upload resume/docs)
Intake application (new client)	/intake/apply	Submit a new client intake request (uploads supporting docs, generates PDF)
Contact form	/contacts	Submit a contact message
Login / password reset	/login, /forgot-password, /reset-password	Authenticate or recover account

3. Admin

Home page after login: /admin/intake — full operational and administrative control

Administrator

Admins have unrestricted visibility and control across the entire platform: they see and can act on every client, therapist, session, invoice, and application — plus exclusive access to staff permissions, hiring, and system audit logs.

Page	Route	Actions available
Dashboard	/admin	View pending intakes, active clients, unpaid invoices, today's sessions, revenue & sessions-by-service charts
Calendar	/admin/calendar	View clinic-wide calendar of all sessions
Intake Pipeline	/admin/intake/*	View / search / filter Create Edit Delete Approve directly (promotes straight to Client) Send to therapist for review Approve/reject on therapist's behalf Update intake status (pending → under review → waitlist/denied/approved), manage documents and internal notes
Clients	/admin/clients/*	View / search / filter Edit Delete Assign/reassign primary therapist and full care team; add/update/remove client's services; upload/delete documents; add/delete notes; view a client's session history
Sessions (scheduling)	/admin/sessions/*	View all (not scoped to any one therapist) Create Edit Delete Cancel Dispute Can assign any therapist to any session. (Cannot "start/end" a live session — that action is therapist-only.)
Service Offerings (billable catalog)	/admin/services/*	View Create Edit (no delete exposed)
Invoices	/admin/invoices/*	View all Create Edit Delete admin-only Generate invoice from a completed session; mark as paid; resend to client
Job Applications	/admin/applications/*	View / filter Delete Update status (interview scheduled, declined, hired — hiring auto-creates a Team Member + user login and emails offer letter); rate applicant 1–5 stars; add/delete internal notes
Team / Staff Management	/admin/team/*	View Create Edit Delete Grant/revoke permissions admin-only — finance access, team management access, client management access, employment status; upload/delete staff documents
Careers (job postings CMS)	/admin/careers/*	View Create Edit Delete job postings
User & Role Management	/admin/users/*	View admin user list Edit any user's name, phone, active status, notification preferences Change any user's role admin-only (promote/demote between admin/therapist/client)
Messages / Complaints	/admin/messages/*	View all complaints/disputes across the whole platform Start review Resolve admin-only

Administrator / System Settings	/admin/administrator*	View system audit log (searchable, filterable by module) Create new admin account (auto-generates password, emails invite) Toggle service visibility on the public site; edit own admin profile
Google Drive Integration	/admin/google-drive/*	Connect/authorize the clinic's Google Drive for document storage

4. Therapist

Home page after login: /therapist — scoped to their own caseload and assignments only

Therapist

Therapists only see data tied to them: their own clients, sessions, invoices, and intake reviews they've been assigned. They cannot see or touch another therapist's caseload, billing, or clients.

Page	Route	Actions available
Dashboard	/therapist	View own stats/overview
Reports	/therapist/reports	View (placeholder page)
Calendar	/therapist/calendar	View own schedule only
My Clients	/therapist/clients	View only clients where they are the primary or assigned therapist / on the care team
Intake Review (assigned)	/therapist/intake/{intake}	View — only intakes specifically assigned to them for review Approve Reject their own assigned review (approving the first service on an intake promotes it to an active Client; approving further services adds them to that client's existing care team)
Sessions (scheduling)	/therapist/sessions/*	View own only Create (locked to themselves as the therapist — cannot assign another therapist) Edit Delete Cancel Dispute (if a participant) Start session End session — unique to therapists (clocking a session in progress)
Invoices	/therapist/invoices/*	View own only Create Edit own only Generate invoice from own completed session; resend own invoice. No delete — deleting invoices is admin-only.
My Profile	/therapist/profile	View Edit own staff profile record; upload/delete own documents
Complaints	/therapist/complaints/*	View only complaints they filed File a new complaint about a session

5. Client

Home page after login: /client/calendar — the most restricted role, scoped strictly to their own record

Client

Clients can only ever view their own data. They cannot create or manage sessions, and cannot create, edit, or delete invoices — those are staff-only actions. Their write access is limited to verifying/disputing their own completed sessions, filing complaints, and editing their own profile details.

Page	Route	Actions available
Calendar (home)	/client/calendar	View own sessions only
Dashboard	/client/dashboard	View (placeholder page)
Reports	/client/reports	View (placeholder page)
Invoices	/client/invoices/*	View own only — read-only , no create/edit/delete
Sessions	/client/sessions/*	Look up own sessions Verify a completed session (sign-off, own sessions only) Dispute a session (creates a complaint) <i>No create, edit, delete, cancel, start, or end — those are staff-only.</i>
Complaints	/client/complaints/*	View only complaints they filed File a new complaint
Profile	/client/profile	View Edit own profile — name, phone, date of birth, address, emergency contact (edits flow onto the linked intake record). Funding/service details are not client-editable.

6. Implementation Notes

How restrictions are enforced:

- Route groups (/admin, /therapist, /client) are each protected by a `role:<name>` middleware — visiting a route outside your role redirects you to your own role's home page.
- Shared controllers (Sessions, Invoices, Complaints) detect the logged-in user's role and automatically scope query results and edit rights — e.g. a therapist's "Sessions" list only ever contains their own sessions, enforced in code rather than by separate pages.
- Some actions (e.g. deleting an invoice, resolving a complaint) have no in-code role check — they are protected solely by only being wired into the admin route group. Functionally admin-only today, but worth flagging if new routes are ever added that expose these controller methods elsewhere.

Account creation paths:

- **Admin** accounts are created only by an existing admin (Administrator → create user).
- **Therapist** accounts are created only by hiring a job applicant (Admin → Applications → mark "Hired").
- **Client** accounts are created only by approving an intake application (either directly by an admin, or by a therapist approving their assigned review).
- Only an admin can change a user's role after the fact.

Generated from the live application route, controller, and middleware definitions. No formal Policy/Gate classes exist in this codebase — this report reflects the effective access rules as implemented in code at the time of generation.